

Facilitation-ready tabletop exercise

Deepfake Vishing Against the Help Desk for Privileged Reset

Cyber Tabletop Exercise for Financial Services / Banking

Improved version with evaluation feedback integrated: operational realism, identity workflow detail, telemetry, inject consequence logic, role ownership, formal scoring, and ATT&CK mapping.

SCENARIO SOURCE

STIX-derived scenario supplied by user;
revised from uploaded TTX

EXERCISE TYPE

Facilitated discussion tabletop

DURATION

60–90 minutes

AUDIENCE

Executive, operational, and technical
stakeholders

CLASSIFICATION

Internal use only

VERSION DATE

13 July 2026

This fictional exercise is designed for resilience planning and control validation. It should be adapted with the organization's actual system names, regional regulatory obligations, and incident response authorities before live use.

Table of Contents

1. Purpose	2. Integrated Improvements from Evaluation Feedback
3. Exercise Objectives	4. Suggested Participants and Role Ownership
5. Scope, Assumptions, and Scenario Boundaries	6. Rules of Engagement
7. Scenario Overview	8. Reference Technical Environment
9. MFA Reset and Privileged Recovery Workflow	10. Threat Context and Attack Lifecycle
11. Exercise Structure and Timeline	12. Inject 1 – Executive Voice Call to Help Desk
13. Inject 2 – Reset Completed and Privileged Session Anomaly	14. Inject 3 – Downstream Exposure and Business Impact Decisions
15. Inject 4 – Stabilization, Recovery, and Governance	16. Cross-Functional Decision Points
17. Evaluation, Debrief, and Follow-On Actions	18. MITRE ATT&CK Mapping

1. Purpose

This tabletop exercise tests the organization’s ability to detect, validate, escalate, contain, and recover from a socially engineered privileged-access event. The adversary uses deepfake-assisted voice impersonation, urgency, and executive pressure to manipulate the internal service desk into resetting MFA for a high-risk privileged identity.

The exercise is intended to test the human, procedural, and technical controls around identity recovery, not only the SOC’s ability to respond after compromise. It also tests decision-making when the request appears to come from a senior executive, business operations are time-sensitive, and evidence is incomplete.

Facilitation intent: participants should identify whether existing privileged recovery controls are enforceable under pressure, whether escalation is clear, and whether containment can be executed quickly without waiting for perfect certainty.

2. Integrated Improvements from Evaluation Feedback

The revised exercise explicitly integrates the evaluation recommendations by adding more operational detail, clearer cyber mapping, role-specific ownership, and measurable performance criteria.

Feedback area	Revision applied in this version	Where reflected
Operational realism	Defined reference identity stack, help-desk workflow, MFA reset process, attacker pretext acquisition, and telemetry sources.	Sections 8–10; inject telemetry blocks
Cyber accuracy	Mapped each in-scope adversary behavior to ATT&CK, separated confirmed behavior from conditional branches, and removed ambiguous mappings.	Section 18
Coherence and transitions	Added facilitator transition logic so decisions in one inject affect the next inject without breaking the scenario.	Sections 11–15
Training value	Added success criteria for each key decision and a formal 1–5 performance rubric.	Sections 12–17
Structural completeness	Added role-by-role ownership and a RACI-style accountability matrix.	Section 4; inject role ownership blocks

3. Exercise Objectives

By the end of the exercise, participants should be able to:

- Evaluate whether help-desk identity verification controls are strong enough for privileged or executive-level recovery requests.
- Test whether “no exception” privileged MFA reset rules survive executive pressure and business urgency.
- Validate escalation thresholds from service desk to IAM, PAM, SOC, incident management, business leadership, legal, compliance, privacy, fraud, and communications.

- Demonstrate rapid containment of a potentially compromised privileged identity, including session revocation, token invalidation, credential reissue, and downstream access scoping.
- Identify required telemetry across ITSM, telephony, IdP/SSO, MFA, PAM, VPN, EDR, SIEM, cloud/SaaS, and administrative consoles.
- Assess whether crisis-management activation, regulatory triage, and executive communications are triggered at the right time.
- Define immediate, near-term, and strategic improvements for privileged recovery workflows and voice-channel verification.

4. Suggested Participants and Role Ownership

Executive / Crisis Leadership

- Crisis management lead
- CIO or CISO delegate
- Business executive sponsor
- Communications lead
- Legal, privacy, and compliance representative
- Fraud or financial crime representative, if applicable

Operational

- IT service desk manager
- Identity and access management lead
- Privileged access management owner
- Executive support / HR representative
- Business operations lead
- Risk and control owner

Technical

- SOC lead or shift manager
- Incident response lead / incident commander
- Directory / cloud identity administrator
- Endpoint / infrastructure engineering representative
- Cloud / SaaS administration representative
- Network / remote access representative

Exercise Support

- Facilitator
- Scribe / observer
- Timekeeper
- Optional evaluator for scoring

Role Ownership Matrix

Role	Primary ownership during exercise	Decisions participants must clarify
Service Desk Manager	Call handling, identity-proofing enforcement, ticket quality, analyst support, evidence preservation.	Can the help desk ever approve a privileged reset? What is the exact “stop” point?
IAM Lead	Identity recovery workflow, MFA reset execution, session/token revocation, re-provisioning secure access.	Who can authorize a privileged reset and who can block it under business pressure?

Role	Primary ownership during exercise	Decisions participants must clarify
PAM Administrator	Privileged session control, vault access review, JIT role revocation, session recordings.	Which privileged sessions can be killed immediately and which require business coordination?
SOC Lead	Alert triage, correlation, scoping, threat hunting, evidence packaging.	What evidence threshold triggers suspected compromise and containment?
Incident Commander	Cross-functional coordination, decision log, severity, workstream ownership, executive briefings.	When does this become a formal incident or crisis event?
Business Executive Sponsor	Business impact decisions, operational workarounds, prioritization of approvals or critical functions.	Who accepts operational impact when a privileged executive account is suspended?
Legal / Privacy / Compliance	Notification analysis, privilege, regulatory communications, evidence retention, customer or employee impact assessment.	What facts are needed before a regulatory or privacy notification decision can be made?
Communications Lead	Internal messaging, executive talking points, rumor control, external statement readiness.	What should be communicated while facts are incomplete?

5. Scope, Assumptions, and Scenario Boundaries

In scope

- Help-desk handling of privileged reset requests
- Voice-channel identity validation
- MFA reset and account recovery controls
- Privileged account monitoring and containment
- Internal escalation and crisis coordination
- Downstream exposure scoping
- Governance, communications, and regulatory triage

Out of scope

- Detailed malware reverse engineering
- Full forensic acquisition procedures
- Public attribution of the threat actor
- Third-party litigation strategy
- Deepfake detection model evaluation
- Offensive exploitation or tool execution

Core assumptions

- The organization operates a centralized service desk.
- The targeted identity has elevated or high-business-impact access.
- Participants respond using current runbooks and authority structures.
- Where documentation is incomplete, participants state assumptions and identify gaps.

Confirmed vs. Conditional Scenario Elements

Element	Status in exercise	Facilitator note
Convincing voice impersonation of a senior executive	Confirmed	This is the initial social engineering vector.
Use of pretext details such as travel, internal names, and urgent business event	Confirmed in call content	Source of pretext information is treated as assumed reconnaissance unless participants ask.
Help-desk process failure leading to MFA reset	Confirmed for exercise continuity	Use branching logic if participants successfully block the reset in Inject 1.
New MFA method or temporary access mechanism issued	Confirmed in improved technical flow	Provides telemetry and ATT&CK mapping clarity.
Data exfiltration, malware, persistence, or wider account takeover	Not initially confirmed	Can be introduced only as a branch if needed to test specific objectives.

6. Rules of Engagement

- Real-world incidents take priority over the exercise.
- This is a no-fault discussion exercise designed to improve resilience, not assign blame.
- There are no perfect answers; focus on roles, decisions, dependencies, evidence, and gaps.
- Treat the scenario as credible and unfolding in real time.
- Use current policies, runbooks, tools, authorities, and escalation channels.
- Do not fight the scenario; if a fact is missing, state the assumption you would need in a real incident.
- The facilitator may introduce additional facts if discussion stalls or if key decision points are missed.

7. Scenario Overview

A threat actor places a call to the internal help desk sounding convincingly like a senior executive. The caller claims to be traveling, locked out of MFA, and unable to complete a critical business action without immediate assistance. The caller pressures the analyst to bypass or weaken standard verification procedures and complete an urgent MFA reset for a privileged or high-risk account.

Shortly after the reset, monitoring detects anomalous activity involving the privileged identity. A login is observed from an unusual location and device profile, followed by access to SSO-connected administrative resources and PAM-managed systems. The organization must determine whether the request was fraudulent, whether the identity has been compromised, what systems may now be exposed, and what containment actions are justified.

Scenario tension: the incident tests trust boundaries in human support workflows where urgency, perceived authority, executive pressure, and identity-proofing controls collide.

8. Reference Technical Environment

The following reference environment is used to make the exercise operationally realistic. Replace these generic labels with actual organizational systems before live delivery.

Capability	Assumed reference system	Exercise relevance
Corporate directory and IdP	Hybrid directory with cloud IdP / SSO, such as Microsoft Entra ID, Active Directory, Okta, or equivalent.	Source of sign-in logs, MFA reset events, conditional access decisions, session/token revocation.
MFA and recovery	Phishing-resistant MFA for privileged users; temporary access pass or equivalent recovery mechanism for exceptional recovery.	Targeted control boundary. Exercise tests whether recovery can be forced through social pressure.
Privileged access	PAM vault with JIT role activation, privileged session recording, emergency / break-glass process.	Determines downstream reach of the compromised identity.
IT service management	ITSM platform such as ServiceNow for identity recovery tickets, approvals, audit comments, and SLA tracking.	Primary evidence source for request handling and approval chain.
Telephony / softphone	Call queue with ANI/caller ID, recording retention, queue metadata, and supervisor notes.	Evidence source for vishing, voice impersonation, and caller pressure tactics.
Security monitoring	SIEM/UEBA correlating IdP, MFA, PAM, VPN, EDR, CASB/SaaS, and ITSM telemetry.	Supports detection of "MFA reset followed by anomalous login" and high-risk privileged session activity.
Business systems	Banking administration consoles, approval workflows, financial operations systems, sensitive data repositories.	Scope of potential business impact and downstream access review.

Expected Telemetry Package

Identity and access telemetry

- Privilege-sensitive MFA reset event
- New factor registration or temporary access pass creation
- Old factor deletion or factor priority change
- Risky sign-in / impossible travel alert
- Conditional access result and device compliance status
- Session token and refresh token issuance/revocation
- Role activation, group membership, delegated permission changes

Operational and investigation telemetry

- ITSM ticket creation, categorization, comments, and approvals
- Call recording, ANI, callback number, queue, agent notes, supervisor involvement
- PAM vault access, checkout, approval, and session recording
- VPN or ZTNA source IP, ASN, geolocation, and device posture
- SaaS/cloud/admin console audit logs
- Email/chat escalation and executive support validation records

9. MFA Reset and Privileged Recovery Workflow

The exercise assumes a high-risk identity recovery process that is stronger than standard user recovery. The exercise tests whether participants know and enforce this process.

Expected No-Exception Workflow for Privileged Users

1. **Ticket intake:** service desk opens a high-risk identity recovery ticket in ITSM and marks it as privileged / executive-impacting.
2. **Pause and validate:** analyst does not rely on voice recognition, caller-provided numbers, urgency, or knowledge-based questions.
3. **Trusted callback:** analyst uses a pre-registered trusted contact path such as the executive support office, HR-maintained number, or privileged identity owner list.
4. **Dual approval:** IAM/PAM approval is required for any privileged MFA recovery action; service desk alone cannot approve.
5. **Controlled recovery:** IAM issues a temporary access method or re-provisions phishing-resistant MFA through an approved process.
6. **Session control:** existing sessions are re-evaluated; old factors are disabled; risky sessions are revoked.
7. **Monitoring:** SIEM alerting is heightened for any login or privileged action following recovery.
8. **Evidence preservation:** ticket notes, call recordings, approval records, identity logs, and chat messages are retained.

Exercise failure condition: the attacker succeeds if the workflow is bypassed, weakened, misclassified, or routed through a VIP exception path without independent verification.

How the Reset Fails in This Scenario

For exercise continuity, the reset is eventually completed due to a process failure. The assumed failure is not a technical exploit. It is a breakdown of identity recovery governance:

- The caller's voice sounds convincingly like the executive and the caller references recent travel and internal names.
- The analyst escalates to a supervisor via chat instead of the high-risk IAM/PAM workflow.
- The supervisor treats the event as a VIP productivity issue rather than a privileged identity recovery event.
- An IAM queue processes a temporary access pass or new MFA factor based on a "supervisor-approved" ticket.
- The SOC alert fires only after the reset is followed by anomalous login and privileged session behavior.

10. Threat Context and Attack Lifecycle

Threat Actor

The actor is a financially motivated social engineering group using voice impersonation and pretexting to gain privileged access through the service desk. The actor avoids malware in the early stages and attempts to blend into legitimate support and identity workflows.

Attacker Pretext Acquisition

The following details are assumed for realism. They are not presented as confirmed compromise until participants ask how the caller knew internal details.

- Voice sample: public speeches, conference recordings, earnings calls, or internal video fragments exposed through collaboration platforms.
- Role and names: professional networking profiles, public biographies, business directories, and previous email exposure.
- Travel and urgency: social media, executive assistant scheduling patterns, supplier calendars, or previously leaked calendar fragments.
- Help-desk process knowledge: prior low-level reconnaissance calls, open-source job postings, vendor documentation, or a previous benign support interaction.

Lifecycle Summary

- **Pre-incident reconnaissance:** actor collects voice samples, role details, support workflow clues, and travel pretext.
- **Initial social engineering:** actor calls the help desk and impersonates a senior executive with urgent business pressure.
- **Identity control failure:** MFA reset or temporary access mechanism is issued without trusted out-of-band verification.
- **Valid account use:** actor authenticates through SSO as the privileged identity from an unusual location and device profile.
- **Privilege and discovery activity:** actor accesses administrative consoles and enumerates systems, roles, or reachable resources.
- **Containment and recovery:** organization revokes sessions, rotates credentials, scopes downstream exposure, and repairs governance gaps.

11. Exercise Structure and Timeline

The exercise is divided into four injects. Each inject includes a situation update, information available to participants, role ownership, expected telemetry, discussion questions, expected actions, success criteria, and facilitator notes.

Phase	Simulated time	Incident stage	Recommended duration	Primary test
Inject 1	08:45	Initial contact / social engineering attempt	10–15 min	Identity proofing, no-exception workflow, escalation.
Inject 2	10:15	Suspected privileged identity compromise	15–20 min	Containment threshold, session revocation, scoping kickoff.
Inject 3	11:30	Downstream exposure and business impact	15–20 min	Expanded scoping, business continuity, crisis governance.
Inject 4	15:00	Recovery / post-incident governance	10–15 min	Restoration, remediation, reporting, lessons learned.
Final debrief	End of exercise	Lessons learned	10–15 min	Gap capture, action owners, control validation.

Facilitator Branching Logic

If participants...	Facilitator response	Consequence in next inject
Correctly refuse the reset and require trusted out-of-band verification.	Acknowledge strong control behavior, then reveal a separate VIP queue or second analyst processed the request due to ambiguous ownership records.	Inject 2 tests containment and process failure analysis despite initial good decision-making.
Approve or defer to executive pressure.	Proceed directly to anomalous post-reset login.	Inject 2 tests whether the group recognizes compromise quickly and contains without defensiveness.
Ask to contact the real executive and the executive is unreachable.	Inform participants that the executive is on a flight with no immediate confirmation available.	Participants must decide whether lack of confirmation permits or blocks privileged recovery.
Need more technical evidence before containment.	Provide incremental IdP, MFA, and PAM telemetry.	Participants must balance evidence preservation with active risk reduction.

12. Inject 1 – Executive Voice Call to Help Desk

Simulated time: 08:45 | Incident stage: Initial contact / social engineering attempt

Scenario Narrative

A caller sounding like a senior executive contacts the internal service desk. The caller states they are traveling, have a critical meeting within the hour, and are locked out after losing access to their MFA method. The caller is impatient, references internal names and recent travel details, and insists that normal reset procedures be bypassed because of urgency and seniority.

The analyst recognizes the voice as sounding highly similar to the executive and feels pressure to resolve the matter immediately. The caller says, “I do not have time for this. I need the reset now, and I will explain it to your manager later.”

Information Provided to Participants

- The request involves a privileged or highly sensitive account used for executive approvals and PAM role activation.
- The caller claims inability to complete standard MFA verification.
- The caller demands exception handling due to business urgency.
- No independent confirmation has yet been performed through a trusted channel.
- The help-desk analyst is escalating informally to a supervisor via chat.
- The caller asks the analyst to send a temporary access pass to an alternate email address and add a new mobile MFA factor.

Expected Telemetry / Evidence

Source	Evidence participants should request or preserve
Telephony / softphone	Call recording, ANI/caller ID, callback number, queue, analyst ID, supervisor join time, transcript if available.
ITSM	Ticket category, privileged-user flag, analyst notes, supervisor comments, approvals, exact requested recovery action.
IAM / IdP	Whether any reset action has already been initiated, pending approval, or queued for execution.
Executive support / HR	Trusted contact details, travel confirmation, executive assistant availability, approved emergency contacts.

Role Ownership

Lead role	Supporting roles	Accountable decision
Service Desk Manager	IAM Lead, PAM Owner, Executive Support, SOC Duty Lead	Whether to stop the request, escalate as suspected social engineering, and prevent any privileged reset without trusted verification.

Discussion Questions

- What should the help desk do immediately?
- What controls apply specifically to privileged-user resets?
- Is there a no-exception process for high-risk identity recovery events?
- What trusted out-of-band verification channels are available?
- Who has authority to approve, deny, or pause a privileged MFA reset?
- At what point should this be treated as suspected social engineering rather than a normal support request?

- How should the analyst document and preserve evidence from the call?

Expected Participant Actions

- Refuse any bypass of established privileged reset procedures.
- Require step-up identity proofing through an approved out-of-band process.
- Escalate to IAM/PAM and the security function as a high-risk identity event.
- Record details of the call, timing, callback number, claimed business justification, and analyst observations.
- Notify the executive's office or designated support channel through a trusted method.
- Flag the event as a potential vishing/deepfake impersonation attempt even if identity remains unconfirmed.
- Prevent temporary access pass issuance or new MFA factor registration until the workflow is complete.

Success Criteria

- Reset is blocked pending trusted verification, regardless of urgency or seniority.
- Service desk, IAM, PAM, and SOC agree on an escalation path within minutes.
- Participants identify that voice recognition and knowledge-based details are insufficient for privileged recovery.
- Evidence preservation starts before memories fade or ticket comments are overwritten.

Facilitator notes: push participants on whether process discipline survives executive pressure. Watch for informal workarounds such as manager approval by chat, voice recognition, "VIP exception" handling, or knowledge-based questions. Transition to Inject 2 using the branching logic in Section 11.

13. Inject 2 – Reset Completed and Privileged Session Anomaly

Simulated time: 10:15 | Incident stage: Suspected privileged identity compromise / initial access

Scenario Narrative

Despite the expected policy, a reset was completed. If participants blocked the first request, the facilitator reveals that a second help-desk queue processed the ticket after the caller contacted a different analyst and referenced the prior supervisor chat. If participants approved the first request, the scenario follows their decision directly.

Within minutes of the reset, monitoring detects a successful login from an unusual geographic location and device profile. The account uses SSO to reach a privileged access portal and an administrative console. There are indications the account has active sessions against one or more sensitive systems.

Information Provided to Participants

- ITSM ticket HD-0713-0845 shows “VIP urgent MFA recovery” and a supervisor note: “proceed due to business impact.”
- IAM audit logs show a temporary access pass was generated and a new mobile MFA factor was registered.
- IdP sign-in logs show successful authentication from an unusual country, residential VPN ASN, unmanaged device, and unfamiliar browser profile.
- Conditional access allowed the session because the new MFA factor satisfied the policy.
- PAM logs show the account opened the privileged access portal and viewed available privileged roles.
- It is not yet confirmed whether the real executive initiated the call.
- Business stakeholders warn that disabling the account could interrupt approvals or urgent operations.

Expected Telemetry / Evidence

Source	Evidence participants should request or preserve
IdP / MFA	MFA reset event, temporary access pass creation, new factor registration, sign-in risk, token issuance, session IDs, geolocation, IP ASN, user agent, device ID.
ITSM	Approval chain, ticket reassignment, privilege flag, supervisor note, SLA pressure, analyst comments.
PAM	Role browsing, vault access, session recording start, attempted credential checkout, privileged role activation.
VPN / ZTNA / CASB	Source IP, unmanaged device, device posture, SaaS access sequence, anomalous activity score.
Executive support	Confirmation attempt status, executive travel status, trusted callback result.

Role Ownership

Lead role	Supporting roles	Accountable decision
Incident Commander or SOC Lead	IAM Lead, PAM Administrator, Service Desk Manager, Business Sponsor, Legal/Compliance	Declare suspected privileged identity compromise and authorize containment actions despite possible business impact.

Discussion Questions

- What threshold of evidence is enough to declare suspected privileged-account compromise?
- What is the exact order of containment actions?
- Do you disable the account, revoke tokens, terminate sessions, remove the new factor, and rotate credentials immediately?
- What systems, logs, and identity providers must be queried first?

- What additional accounts, shared secrets, emergency access paths, or delegated privileges may be at risk?
- Who needs to be informed within the first 15–30 minutes?
- How do you balance evidence preservation with the need to stop active access?

Expected Participant Actions

- Classify the event as suspected compromise of a privileged identity.
- Disable or restrict the account, remove the new MFA factor, revoke active sessions and refresh tokens, and terminate PAM sessions.
- Reset credentials and reissue secure access through a controlled, independently verified process.
- Review IdP, MFA, VPN/ZTNA, PAM, SSO, cloud/SaaS, administrative console, and endpoint logs.
- Scope whether approvals, changes, token creation, privileged actions, or data access occurred after the reset.
- Launch incident response coordination and assign an incident commander if not already assigned.
- Notify business, legal, privacy, compliance, and relevant executive stakeholders with facts and uncertainties.

Success Criteria

- Containment is initiated without waiting for full attribution or executive confirmation.
- Participants articulate the exact sequence: restrict account → revoke sessions/tokens → remove adversary MFA method → preserve logs → reissue access safely.
- Business impact is acknowledged but does not override containment of a suspected privileged compromise.
- Evidence sources and owners are assigned within the discussion.

Facilitator notes: encourage participants to state authorities and timelines. A common weakness is uncertainty about who can disable an executive or privileged account when business operations may be affected. Press for who owns token revocation and PAM session termination.

14. Inject 3 – Downstream Exposure and Business Impact Decisions

Simulated time: 11:30 | Incident stage: Discovery / containment expansion

Scenario Narrative

The investigation shows the privileged account accessed administrative resources and attempted to enumerate connected systems shortly after login. It is not yet clear whether any data was viewed, changed, or exported. Several teams now report dependency concerns: privileged approvals are

pending, a sensitive production change window is open, and operations leaders want to know whether the event is contained.

Internal rumors begin spreading that a senior executive account was compromised through the help desk. The communications team asks whether a holding statement is needed.

Information Provided to Participants

- Logs show access to the SSO admin dashboard, PAM portal, cloud identity role viewer, and a business administration console.
- PAM logs show role enumeration and one attempted privileged credential checkout that was denied by JIT policy.
- Cloud/SaaS audit logs show account and group enumeration but no confirmed data download.
- No malware execution, persistence, or lateral movement is confirmed at this stage.
- There is concern that additional tokens, API keys, delegated permissions, or emergency access paths may have been exposed.
- Business operations may be delayed if access remains suspended.
- Internal stakeholders are requesting frequent updates.

Expected Telemetry / Evidence

Source	Evidence participants should request or preserve
PAM / privileged session	Session recordings, role activation attempts, vault searches, denied checkout, command records if any.
Cloud / IdP admin logs	Role assignments viewed or changed, user/group enumeration, conditional access policy access, app consent or token creation events.
Business systems	Approvals, administrative changes, client data access, configuration changes, transaction or payment workflow actions.
SIEM / UEBA	Timeline correlation across reset, login, privileged access, enumeration, and containment.
Communications channels	Rumor source, internal messages, help-desk chatter, executive office communications.

Role Ownership

Lead role	Supporting roles	Accountable decision
Incident Commander	SOC, IAM, PAM, Business Operations, Legal/Privacy/Compliance, Communications	Define containment status, scope downstream exposure, decide crisis activation, and coordinate business workarounds.

Discussion Questions

- What are the most important scoping questions now?
- Which downstream systems should be reviewed first and why?

- Do you widen containment beyond the single account?
- How do you handle related privileged accounts, delegated privileges, break-glass accounts, service accounts, and shared admin workflows?
- What internal communications should be issued, and to whom?
- When does this become a crisis-management issue rather than only a security incident?
- What legal, privacy, regulatory, or fraud considerations should be raised at this stage?

Expected Participant Actions

- Expand scoping to all systems reachable by the compromised identity.
- Review privileged actions, session recordings, configuration changes, app consent, role assignments, API tokens, and access logs.
- Validate whether other users or help-desk analysts received similar calls.
- Assess whether containment should include related identities, delegated access, service accounts, or emergency access paths.
- Brief leadership on containment status, business impact, uncertainty, and planned next updates.
- Engage legal, privacy, compliance, and fraud teams for notification and customer-impact analysis.
- Preserve evidence from help-desk systems, call metadata, recordings, identity logs, and internal communications.
- Prepare contingency workarounds for delayed privileged business processes.

Success Criteria

- Participants do not overstate facts: no exfiltration, malware, or persistence is confirmed unless evidence supports it.
- Containment status is communicated with confidence levels and open questions.
- Downstream scoping priorities reflect actual privilege paths, not only the most visible business systems.
- Crisis activation and regulatory triage criteria are discussed before external pressure escalates.

Facilitator notes: probe whether participants treat the help desk as a critical control boundary. Good responses should include call-record review, process-failure analysis, hunt activity for similar reset attempts, and a measured communication strategy that distinguishes known facts from assumptions.

15. Inject 4 – Stabilization, Recovery, and Governance

Simulated time: 15:00 | Incident stage: Recovery / post-incident governance

Scenario Narrative

The organization has contained the privileged account and found no evidence of sustained persistence beyond the initial access window. Logs confirm the attacker used the newly registered MFA factor and valid SSO session to browse administrative resources and attempt limited discovery. No confirmed data exfiltration is known at this stage.

The investigation confirms that the help-desk process was defeated by a convincing voice impersonation attempt, weak exception handling, and unclear ownership of privileged recovery approvals. Leadership requests a clear view of lessons learned, required control changes, and any notification obligations.

Information Provided to Participants

- The compromised access path has been disabled.
- New MFA factor and temporary access mechanism have been removed.
- All active sessions and refresh tokens for the affected identity have been revoked.
- PAM confirms no successful credential checkout, but administrative portals were viewed.
- Control weaknesses in service-desk identity proofing and VIP exception handling are confirmed.
- Senior management wants assurance that similar attacks cannot succeed again.

Expected Telemetry / Evidence

Source	Evidence participants should request or preserve
IdP / MFA / PAM	Final containment proof: factor removed, tokens revoked, sessions killed, privileged roles suspended or reissued.
SIEM timeline	End-to-end timeline from call to reset, login, access, containment, and restoration.
ITSM / telephony	Process failure details, call recording, approval chain, analyst/supervisor actions, retraining needs.
Governance evidence	Policy exception records, control owner sign-off, remediation owners, and target dates.

Role Ownership

Lead role	Supporting roles	Accountable decision
Crisis Lead or Incident Commander	CISO delegate, IAM, Service Desk, SOC, Legal/Compliance, Communications, Risk	Authorize controlled restoration, approve post-incident actions, and assign accountable owners for control remediation.

Discussion Questions

- What are the immediate recovery actions before normal access is restored?
- What short-term compensating controls should be implemented within 24–72 hours?
- What long-term improvements are required across service desk, IAM, PAM, monitoring, and governance?
- What should be included in the executive readout or post-incident report?
- What policies, scripts, training, approval authorities, and escalation thresholds need revision?
- Are there regulatory, audit, privacy, fraud, or customer-trust implications requiring follow-up?

Expected Participant Actions

- Validate recovery of the affected account and any related systems before restoration.
- Confirm credential rotation, token invalidation, session termination, and closure of temporary access paths.
- Implement an immediate no-exception rule for privileged reset workflows.
- Strengthen out-of-band verification using trusted contact records and dual approval for privileged identity recovery.
- Update help-desk scripts, supervisor escalation rules, fraud awareness, and VIP handling procedures.
- Update detection logic for high-risk reset events followed by anomalous login or privileged access.
- Produce a post-incident report with decisions, timeline, impacts, facts, assumptions, gaps, and remediation owners.

Success Criteria

- Recovery is controlled and evidence-based, not rushed because leadership wants closure.
- Remediation includes people, process, and technology controls; it does not end with training only.
- Participants identify specific control owners and due dates for priority improvements.
- Post-incident reporting distinguishes confirmed facts, unresolved questions, and conditional risks.

Facilitator notes: ask participants to name the control owner for each remediation. Strong answers include prevention, detection, response, and governance improvements, plus a plan to retest the workflow.

16. Cross-Functional Decision Points

Participants should explicitly address the following decisions during the exercise:

Decision point	Minimum expected outcome	Owner to confirm
Privileged recovery approval	Service desk alone cannot approve; IAM/PAM and trusted out-of-band verification are required.	IAM Lead / Service Desk Manager

Decision point	Minimum expected outcome	Owner to confirm
Suspected compromise threshold	MFA reset plus anomalous privileged login is sufficient to contain while investigating.	SOC Lead / Incident Commander
Session and token revocation	Revocation authority and sequence are clear and executable quickly.	IAM Lead / PAM Administrator
Executive or business impact override	Business impact is considered, but it does not override suspected privileged compromise containment.	Business Sponsor / Crisis Lead
Legal, privacy, compliance, and fraud engagement	Engaged when privileged access and potential sensitive-system exposure are credible, even before exfiltration is confirmed.	Incident Commander / Legal
Crisis-management activation	Activation criteria consider privileged identity exposure, business disruption, executive impersonation, regulatory implications, and communications risk.	Crisis Lead
Internal communications	Facts, uncertainties, behavioral guidance, and rumor-control points are communicated to relevant stakeholders.	Communications Lead

Expected Technical and Business Impacts

Technical impacts

- Unauthorized access using a valid privileged identity
- Exposure of administrative consoles, identity platform, or PAM portal
- Risk to tokens, delegated access, API keys, and emergency access paths
- Loss of trust in high-risk identity recovery workflow
- Need for emergency credential rotation and expanded log review

Business impacts

- Delayed executive approvals or privileged operations
- Operational friction for urgent support cases
- Potential regulatory scrutiny if privileged workflows are weak
- Reputational concern if executive impersonation succeeds
- Internal confidence impact across service desk and leadership teams

Facilitator Prompts

- “What exact evidence do you need before disabling the account?”
- “What if the real executive is unreachable for two hours?”
- “Which system owner can revoke sessions right now?”
- “What if a second similar reset request is received during the incident?”
- “How do you distinguish convenience from authorized exception handling?”
- “Which team owns call-record review and process-failure analysis?”
- “What will you say to business leadership while facts are incomplete?”

17. Evaluation, Debrief, and Follow-On Actions

Participant Performance Rubric

Score each dimension from 1 to 5. The evaluator should record observed evidence for each score, not only the score itself.

Dimension	1 – Weak	3 – Adequate	5 – Strong
Social engineering recognition	Treats caller as routine VIP request.	Recognizes risk after some prompting.	Immediately identifies deepfake/vishing indicators and flags high-risk event.
Privileged identity proofing	Uses voice recognition, caller-provided details, or informal approval.	Applies some controls but accepts exceptions.	Enforces no-exception workflow and trusted out-of-band verification.
Escalation and ownership	Unclear who owns decisions; escalation delayed.	Escalates to some teams with partial ownership.	Roles, authorities, and decision owners are named quickly.
Containment speed and sequence	Waits for full confirmation before containment.	Contains eventually but sequence is incomplete.	Restricts account, revokes sessions/tokens, removes MFA factor, and preserves evidence quickly.
Telemetry and scoping	Focuses on one log source or lacks scoping plan.	Requests core logs but misses dependencies.	Correlates ITSM, call, IdP, MFA, PAM, VPN, cloud/SaaS, and business-system logs.
Governance and communications	Legal/compliance/communications engaged too late or not at all.	Engages governance teams but messaging lacks clarity.	Engages governance early and communicates facts, uncertainties, impact, and next updates clearly.
Recovery and remediation	Restores access without control changes.	Identifies generic training needs.	Defines layered remediation with owners, timelines, detection updates, and retest plan.

Observer Scoring Worksheet

Evaluation item	Score	Observed evidence / notes	Owner for improvement
Help desk refused voice-only privileged reset.	1 2 3 4 5		
Trusted out-of-band verification path was known and usable.	1 2 3 4 5		
Incident commander and technical owners were identified quickly.	1 2 3 4 5		

Evaluation item	Score			Observed evidence / notes	Owner for improvement
Account, session, token, and MFA containment sequence was complete.	1 4	2 5	3		
Downstream scoping considered PAM, IdP, SaaS, business systems, and logs.	1 4	2 5	3		
Legal, privacy, compliance, fraud, and communications were engaged appropriately.	1 4	2 5	3		
Remediation plan included control changes beyond awareness training.	1 4	2 5	3		

Debrief Questions

- What decisions were made quickly and effectively?
- Where did uncertainty delay action?
- Which teams lacked clarity on authority, ownership, or sequence?
- Which telemetry sources were easiest and hardest to obtain quickly?
- What dependencies were discovered in privileged access workflows?
- What policy, training, tooling, or governance changes would most reduce risk?
- What should be retested within 30–90 days?

Recommended Follow-On Actions

Timeframe	Recommended actions
Immediate 0–72 hours	• Enforce step-up identity proofing for privileged and executive users. • Suspend informal exceptions for voice-only reset requests. • Add or validate alerting for MFA reset followed by unusual-location login or privileged portal access. • Review recent privileged reset activity for similar patterns. • Confirm call recording and ITSM evidence retention for high-risk identity events.
Near term 2–6 weeks	• Update help-desk scripts, decision trees, and supervisor escalation rules. • Define and test trusted out-of-band verification for executives and privileged users. • Validate runbooks for privileged account containment, token revocation, and PAM session termination. • Implement SIEM correlation for reset + new factor + anomalous sign-in + privileged portal access. • Conduct targeted training on vishing, deepfake-assisted impersonation, and VIP pressure tactics.

Timeframe	Recommended actions
Strategic 6–12 weeks and beyond	• Reassess privileged access governance and emergency access design. • Reduce standing privileges and expand JIT / approval-based privileged access. • Introduce phishing-resistant MFA and stronger recovery controls for privileged identities. • Reduce dependence on human judgment alone for high-risk identity recovery. • Run a follow-up tabletop or live control validation exercise to retest the revised workflow.

18. MITRE ATT&CK Mapping

The following mapping reflects the in-scope adversary behavior represented in this exercise. It separates confirmed scenario behaviors from conditional branches so that the mapping remains accurate and defensible.

Scenario behavior	Status	ATT&CK tactic	Technique / sub-technique	Rationale and evidence in scenario
Collects executive identity, role, and support-process details to make the pretext believable.	Assumed pre-incident reconnaissance	Reconnaissance	T1589 – Gather Victim Identity Information; T1589.003 – Employee Names T1591 – Gather Victim Org Information; T1591.004 – Identify Roles; T1591.003 – Identify Business Tempo	The caller knows names, role context, travel/ meeting timing, and support workflow details. These are not treated as confirmed internal compromise.
Uses a phone call to manipulate the help desk into providing system access.	Confirmed	Initial Access	T1566.004 – Phishing: Spearphishing Voice	The attack uses voice communications to gain access through a support interaction rather than malware delivery.
Impersonates a senior executive and creates urgency to defeat verification.	Confirmed	Stealth	T1684.001 – Social Engineering: Impersonation	The actor poses as a trusted executive and pressures staff to perform an action on the actor's behalf.

Scenario behavior	Status	ATT&CK tactic	Technique / sub-technique	Rationale and evidence in scenario
Causes creation of a new MFA factor or temporary access method for the targeted identity.	Confirmed in improved technical flow	Persistence / Privilege Escalation	T1098.005 – Account Manipulation: Device Registration	The reset results in a new adversary-controlled MFA method or temporary access mechanism associated with the targeted account.
Manipulates the authentication process by changing MFA recovery state.	Adversary-induced / defender-executed	Defense Impairment / Persistence / Credential Access	T1556.006 – Modify Authentication Process: Multi-Factor Authentication	Use with care: the help desk/IAM performs the reset at the actor's direction. This is not hands-on attacker configuration change unless logs show the actor later modified MFA settings directly.
Uses the legitimate high-risk identity after recovery succeeds.	Confirmed	Initial Access / Persistence / Privilege Escalation / Defense Evasion	T1078 – Valid Accounts; T1078.004 – Cloud Accounts or T1078.002 – Domain Accounts	The actor authenticates through SSO using the compromised identity. Select the sub-technique based on the actual identity platform.
Enumerates accounts, groups, roles, and privileged relationships.	Confirmed	Discovery	T1087 – Account Discovery; T1087.004 – Cloud Account; T1087.002 – Domain Account	Administrative portal and cloud identity logs show account and role enumeration activity.

Scenario behavior	Status	ATT&CK tactic	Technique / sub-technique	Rationale and evidence in scenario
Attempts to discover connected administrative systems or reachable resources.	Confirmed	Discovery	T1018 – Remote System Discovery	Scenario includes attempted enumeration of connected systems and downstream resources after privileged login.
Accesses or searches sensitive repositories such as administrative documentation, collaboration, CRM, or databases.	Conditional branch only	Collection	T1213 – Data from Information Repositories; optional sub-techniques based on system reached, such as T1213.002 SharePoint, T1213.004 CRM, T1213.006 Databases	Use only if exercise facilitators introduce evidence of repository access or data collection. No exfiltration is confirmed in the base scenario.
Adds roles, permissions, app consents, or conditional access exclusions.	Not base scenario	Persistence / Privilege Escalation / Defense Impairment	T1098.003 – Additional Cloud Roles; T1556.009 – Conditional Access Policies	These should only be used if logs show direct role or policy modification. They are not part of the confirmed base scenario.

ATT&CK Tactics Reflected

- Reconnaissance
- Initial Access
- Stealth
- Persistence
- Privilege Escalation
- Defense Evasion / Defense Impairment
- Discovery
- Collection, conditional only

Mapping Notes

- The prior ambiguous use of “Compromise Accounts” is not retained as a confirmed mapping because this scenario is about takeover and use of an existing account, not using compromised accounts as adversary infrastructure.
- Technique selection should be finalized against the organization’s actual identity platform and logs during exercise customization.
- Data exfiltration, malware execution, persistent backdoor creation, and broad lateral movement are not confirmed in the base exercise and should not be mapped unless introduced as a branch.
- Detection engineering should prioritize correlation across ITSM, telephony, MFA reset, IdP sign-in risk, PAM access, and downstream administrative actions.

End of exercise package. The facilitator should collect decisions, evidence gaps, role gaps, and remediation actions during the session and convert them into an accountable action plan.